

IMPLEMENTATION GUIDE

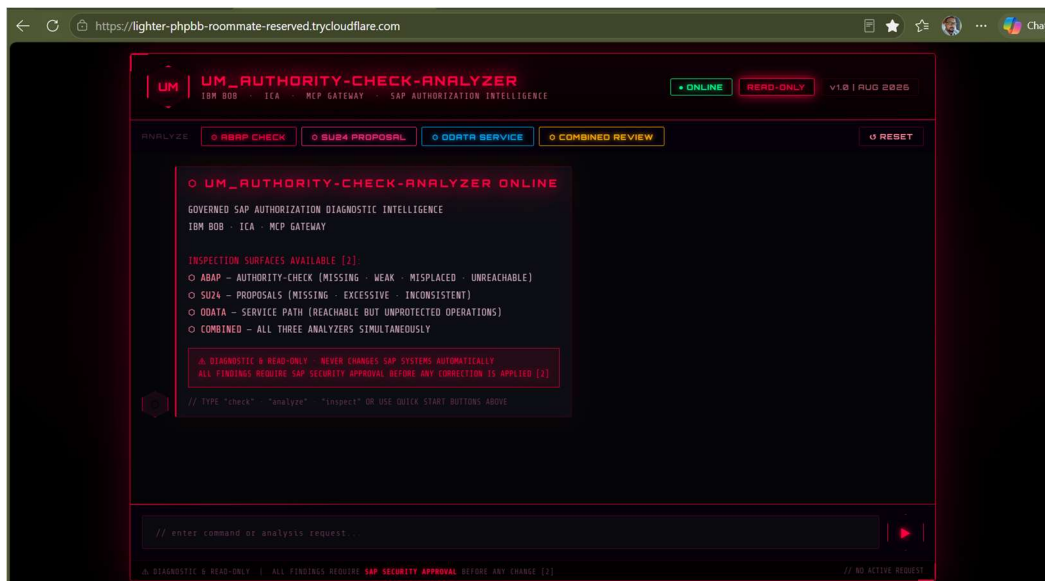
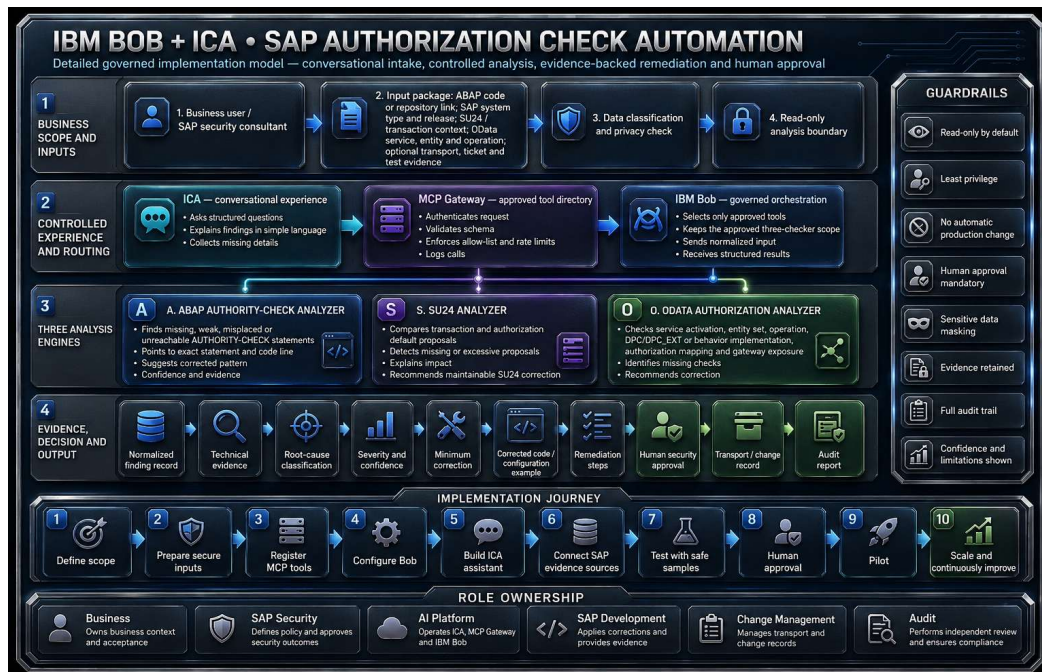
IBM BOB + ICA

SAP Authorization Check Automation

LINK: [UM AUTHORITY-CHECK-ANALYZER | SAP AUTHORIZATION INTELLIGENCE](https://lighter-phpbb-roommate-reserved.trycloudflare.com/)

<https://lighter-phpbb-roommate-reserved.trycloudflare.com/>

A detailed, governed implementation model explained in simple language



The central idea

ICA is the friendly conversation layer. MCP Gateway is the controlled door. IBM Bob is the analysis coordinator. The three approved analyzers inspect ABAP, SU24 and OData security evidence. The system recommends actions, but a qualified human remains responsible for approval and production change.

Prepared as an implementation blueprint. Exact platform screen names, interfaces and enterprise approvals must be confirmed in the target IBM environment.

HOW TO USE THIS GUIDE

This guide is written for people who understand SAP security or business processes but may not be specialists in artificial intelligence. It explains what the solution does, why each part exists, how to implement it safely, and how to prove that it works.

- Read Sections 1–3 to understand the idea and the responsibilities.
- Use Sections 4–13 as the step-by-step build plan.
- Use Sections 14–17 for testing, pilot, operations and scale-up.
- Use the appendices as ready-to-copy checklists and sample records.

IMPORTANT SAFETY BOUNDARY

Default operating rule

The first release must be diagnostic and read-only. It may inspect approved evidence and produce findings, explanations and recommendations. It must not directly change SAP roles, SU24, ABAP code, OData configuration or production data. Any change must go through the existing human approval and change-management process.

QUICK CONTENTS

Section	What it explains
1	What problem the solution solves
2	What the complete solution looks like
3	The three security analyzers
4–13	Detailed implementation steps
14	Testing and acceptance
15	Pilot and rollout
16–17	Day-to-day operations and governance
Appendices	Templates, sample finding and checklists

1. WHAT PROBLEM DOES THIS SOLUTION SOLVE?

In a normal SAP project, a consultant or developer may have to manually inspect code, transaction proposals and OData services to answer a simple question: “Can this business action be performed safely, and are the required authorization checks present?” The work can take time, and the final explanation may depend on the experience of the person doing the review.

This solution creates a repeatable assistant. A user explains the requirement in a conversation or submits a structured package. The assistant sends the package through a controlled gateway. IBM Bob coordinates only the approved security checks. The result is a clear finding with evidence, root cause, severity, confidence, correction guidance and an audit trail.

WHAT THE SOLUTION IS NOT

- It is not a replacement for SAP Security, SAP Development or Change Management.
- It is not a magic button that grants access or fixes production automatically.
- It is not allowed to guess when evidence is missing. It must say “not enough evidence” and ask for more information.
- It is not allowed to hide uncertainty. Every material conclusion must show supporting evidence and limitations.

2. COMPLETE SOLUTION IN SIMPLE LANGUAGE

Part	Simple meaning	Main responsibility
ICA	The chat window where a person asks questions and provides inputs.	Collects complete, understandable information.
MCP Gateway	The guarded entrance that decides which tools may be called.	Authentication, allow-list, input validation, rate limits and logging.
IBM Bob	The coordinator that chooses the approved analysis sequence.	Orchestration, scope control and consistent output.
ABAP analyzer	Looks inside ABAP code for authorization-check weaknesses.	Finds exact statements, lines, risk and correction pattern.
SU24 analyzer	Checks whether transaction defaults support the intended authorization design.	Finds missing or excessive proposals and suggests maintainable corrections.
OData analyzer	Checks service entry points and how business operations are protected.	Finds missing or weak authorization controls around the service.
Evidence and report layer	Keeps the proof and presents the result.	Finding record, evidence, confidence, recommendation and audit trail.
Human approval	A qualified person makes the final decision.	Accept, reject, clarify or send back for correction.

3. THE THREE SECURITY ANALYZERS

3.1 ABAP AUTHORITY-CHECK ANALYZER

This analyzer reads an approved ABAP source package. It looks for authorization-relevant statements and checks whether they are present in the right place, use the right object and fields, and protect the sensitive business action. It should point to the exact code line or statement that caused the finding.

- Example question: "Does this program check whether the user may change the company code before saving the document?"
- Expected result: exact location, detected object and fields, risk explanation, corrected code pattern, confidence and evidence.

3.2 SU24 ANALYZER

SU24 is used to maintain authorization proposals for transactions and applications. In simple terms, it helps SAP know which authorization objects should normally be considered when a transaction is used. The analyzer compares the requested business action with the proposal information and identifies missing, weak, excessive or inconsistent entries.

- Example question: "The transaction starts successfully, but the generated role does not contain the expected authorization object. Is the proposal missing?"
- Expected result: affected transaction or application, proposal state, reason, recommended maintainable correction and validation steps.

3.3 ODATA AUTHORIZATION ANALYZER

OData services are used by many SAP Fiori applications and integrations. This analyzer follows the service path: service, entity, operation, implementation and authorization decision. It looks for a gap between "the service is technically reachable" and "the business action is properly protected."

- Example question: "Can this Fiori service read or change data without checking the user's company code or business role?"
- Expected result: service and entity details, operation, implementation point, authorization evidence, root cause and recommended correction.

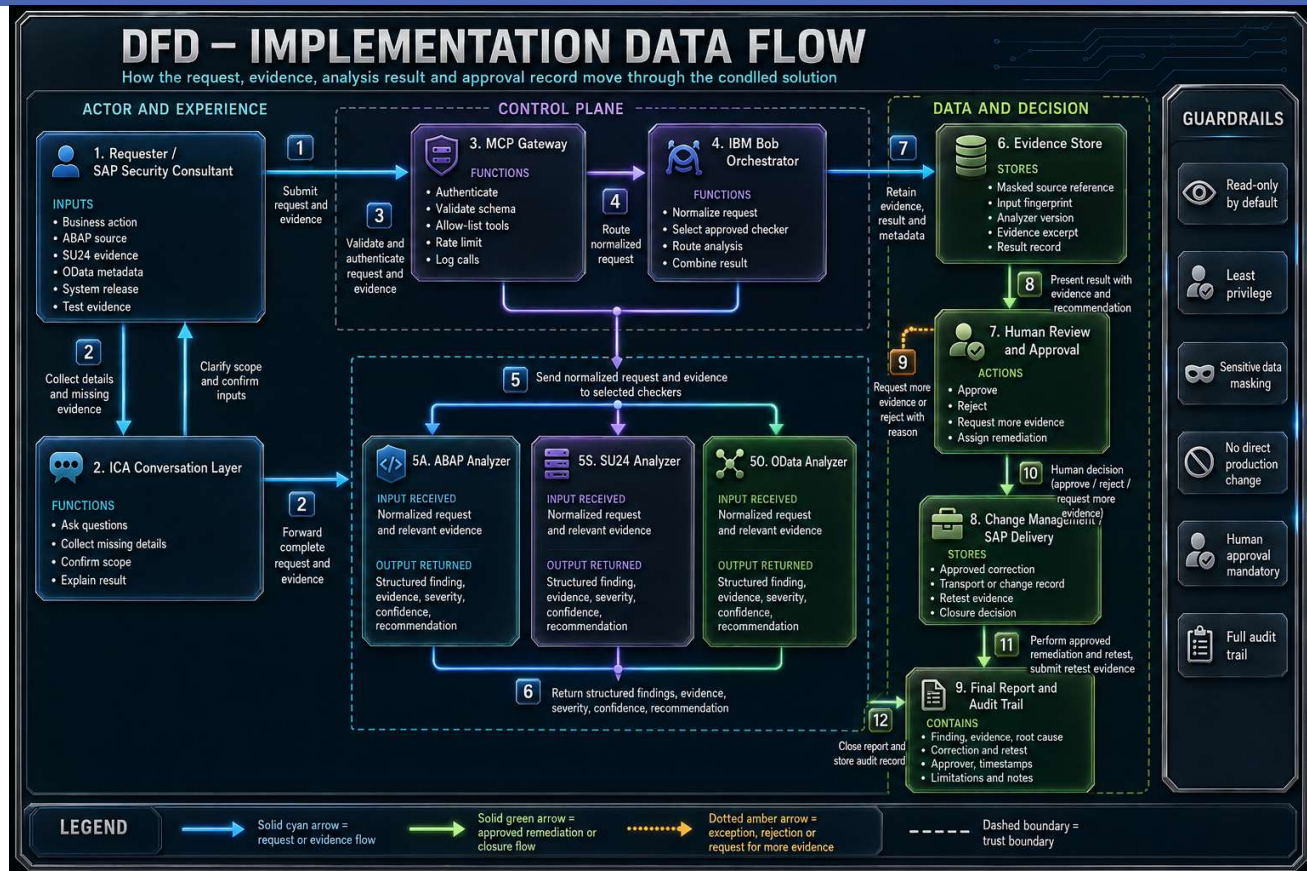
4. IMPLEMENTATION PRINCIPLES EVERYONE MUST UNDERSTAND

Principle	Meaning in everyday language	How to enforce it
Read-only first	The first version observes and advises; it does not change anything.	Use read-only service accounts and disable write tools.
Least privilege	Each component receives only the access it needs.	Separate roles for ICA, gateway, analyzers, evidence store and administrators.
Human approval	The system may recommend, but a responsible expert decides.	Use an approval state before any change ticket or transport recommendation is accepted.
Evidence before conclusion	No proof means no confident answer.	Require source reference, line, object, service or configuration evidence.
Mask sensitive data	Do not send personal, financial or production secrets into prompts.	Mask identifiers and filter fields before analysis.
Explain limitations	The result must say what it could not inspect.	Show missing inputs, unsupported release or incomplete evidence.
Full audit trail	Someone must be able to reconstruct what	Record request, tool, version, input hash,

happened later.

result, approver and timestamp.

5. STEP-BY-STEP IMPLEMENTATION PLAN



STEP 1: DEFINE THE SCOPE AND SUCCESS CRITERIA

In simple words: First decide exactly what the first release is allowed to inspect. A narrow scope is easier to test and safer to operate.

WHAT TO DO

- Approve the three initial surfaces: ABAP AUTHORITY-CHECK, SU24 proposals and OData service authorization entry points.
- Write down what is out of scope for Release 1, such as automatic role generation, automatic SU24 maintenance, automatic transport release, production writes and unrelated code-quality checks.
- Define the expected result fields: finding, affected object, exact evidence, business impact, severity, confidence, correction, retest and limitation.
- Define success in measurable terms: correct finding location, understandable explanation, no unauthorized write, complete audit record and acceptable response time.

WHAT PROVES THAT THE STEP IS COMPLETE

- Signed scope statement.

- Approved list of inputs and outputs.
- Out-of-scope register.
- Acceptance criteria agreed by SAP Security, SAP Development and Change Management.

Primary owner: SAP Security Architect with Business and AI Platform owners

STEP 2: PREPARE SECURE INPUTS

In simple words: Create one standard package so that the assistant receives complete and comparable information every time.

WHAT TO DO

- Create a simple intake form with request ID, requester, project, system type, SAP release, client, business process and change ticket.
- For ABAP, accept a controlled file or repository reference, program/object name, package and relevant include names. Do not accept executable files.
- For SU24, capture transaction or application name, intended business action, expected authorization objects and existing proposal evidence.
- For OData, capture service name, version, entity set, operation, application or tile, implementation reference and test evidence.
- Add a privacy step that removes passwords, tokens, personal identifiers, customer data and unrelated production content.
- Assign a unique request ID and calculate an input fingerprint or hash so the evidence can later be linked to the exact package that was reviewed.

WHAT PROVES THAT THE STEP IS COMPLETE

- Completed intake example.
- Masked sample package.
- Input validation rules.
- Request ID and evidence storage location.

Primary owner: SAP Security and AI Platform teams

STEP 3: CREATE THE COMMON DATA CONTRACT

In simple words: Define one fixed structure for information going into the analyzers and one fixed structure for results coming back.

WHAT TO DO

- Create an input envelope containing request ID, requester, system metadata, analysis type, source references, evidence files and declared limitations.
- Create an output envelope containing finding ID, checker name, status, severity, confidence, evidence, root cause, recommendation, corrected example, retest method and approval state.
- Use controlled values for severity, such as Critical, High, Medium, Low and Informational.
- Use controlled values for status, such as Pass, Finding, Needs More Evidence, Not Applicable and Tool Error.
- Reject unknown fields or malformed records before the analyzer runs. This prevents the system from silently misunderstanding an input.

WHAT PROVES THAT THE STEP IS COMPLETE

- Versioned input schema.
- Versioned output schema.
- Positive and negative validation examples.
- Error messages written in plain language.

Primary owner: AI Platform owner with SAP Security architect

MINIMUM INPUT ENVELOPE EXAMPLE

Field	Example	Why it matters
request_id	AUTH-2026-00017	Connects every action and report.
system	S/4HANA Private Edition; release declared by requester	Prevents applying the wrong rule to the wrong release.
scope	ABAP_AUTHORITY_CHECK	Tells Bob which analyzer is permitted.
source_ref	Program / include / repository reference	Shows where the evidence came from.
business_action	Change sales document for company code	Explains the business meaning behind the code.
evidence	Code excerpt, trace, configuration export or test result	Supports the conclusion.
privacy_status	Masked and approved	Shows that sensitive data was handled.

STEP 4: REGISTER APPROVED TOOLS IN THE MCP GATEWAY

In simple words: The gateway is the guarded entrance. ICA and Bob should not call raw tools directly.

WHAT TO DO

- Create one tool registration for each approved analyzer and one read-only evidence retrieval capability where required.
- Give every tool a clear name, purpose, input schema, output schema, owner, version and allowed environment.
- Allow only the exact operations required for the first release. For example, allow reading source evidence but do not register a write operation.
- Add authentication, authorization, request validation, rate limiting, timeout, retry and logging rules.
- Define failure behaviour: if the gateway cannot validate, it must stop the request and return a safe explanation rather than guessing.
- Record tool versions so that two reports created months apart can be compared honestly.

WHAT PROVES THAT THE STEP IS COMPLETE

- Tool catalogue showing approved status.

- Successful schema validation test.
- Rejected unauthorized-tool test.
- Gateway logs showing request ID, user, tool and result status.

Primary owner: AI Platform / MCP Gateway owner

STEP 5: CONFIGURE IBM BOB AS THE GOVERNED ORCHESTRATOR

In simple words: Bob should coordinate the work, not make up new checks or bypass the gateway.

WHAT TO DO

- Give Bob a strict operating instruction: use only the registered tools and only the approved three-checker scope.
- Tell Bob to ask for missing information before analysis, especially system release, source reference, business action and evidence type.
- Tell Bob to return structured results first and a friendly explanation second.
- Tell Bob to separate facts, interpretation, recommendation and uncertainty.
- Tell Bob never to claim that a role, code or configuration was changed unless a separate approved process has actually completed that change.
- Add a stop condition for high-risk cases, missing evidence, production requests, suspected data leakage or conflicting analyzer results.

WHAT PROVES THAT THE STEP IS COMPLETE

- Bob configuration version recorded.
- Prompt or instruction review completed by SAP Security.
- Tool allow-list test passed.
- Stop-condition test passed.

Primary owner: IBM Bob product owner with SAP Security approver

STEP 6: BUILD THE ICA CONVERSATIONAL ASSISTANT

In simple words: ICA makes the technical engine easy for a person to use without requiring the person to know the internal tool names.

WHAT TO DO

- Create a welcome message that explains what the assistant can inspect and what it cannot change.
- Ask questions in a logical order: objective, system, release, business action, source evidence, analysis type and change ticket.
- Use simple choices where possible: ABAP, SU24, OData or combined review.
- Show a review screen before analysis: "You are asking us to inspect X in system Y using evidence Z. Continue?"
- After analysis, show a short answer first and allow drill-down into evidence, root cause, correction and retest.
- Provide a download or record reference for the final report, subject to enterprise data-handling rules.

WHAT PROVES THAT THE STEP IS COMPLETE

- Conversation script approved by business and security users.
- Missing-input prompts tested.
- User confirmation step demonstrated.

- Readable report demonstrated with a real but sanitized sample.

Primary owner: ICA experience owner

STEP 7: IMPLEMENT THE ABAP ANALYZER

In simple words: This component should explain exactly where the authorization weakness exists and how to correct the pattern.

WHAT TO DO

- Parse the source into a safe internal representation. Treat the source as text to inspect, not as code to execute.
- Identify authorization-relevant statements, objects, fields, values, branches, loops, exits and calls to related routines.
- Check whether the check exists, whether it is reachable, whether the result is actually evaluated, and whether the checked fields match the business action.
- Link each finding to the smallest useful evidence unit: program, include, line range, statement and surrounding context.
- Generate a corrected example that follows the approved coding pattern, but clearly label it as a recommendation requiring developer review.
- Return confidence and reason. For example, high confidence when a sensitive operation has no nearby check; lower confidence when the check may be delegated to a called routine not supplied in the input.

WHAT PROVES THAT THE STEP IS COMPLETE

- Unit tests for present, missing, misplaced and unreachable checks.
- Line-level evidence test.
- Called-routine limitation test.
- False-positive review by an ABAP and SAP Security expert.

Primary owner: ABAP engineering owner with SAP Security

STEP 8: IMPLEMENT THE SU24 ANALYZER

In simple words: This component checks whether the authorization proposals support the intended transaction or application design.

WHAT TO DO

- Read the approved SU24 export or equivalent evidence using a read-only connection or sanitized file.
- Identify the transaction, application, authorization object, field and proposal status.
- Compare the expected business action with the available proposal information.
- Detect missing proposals, proposals that are too broad, proposals that do not match the operation, and evidence that is too old or incomplete.
- Explain the difference between a proposal issue and a role-design issue. Do not recommend adding a broad authorization when a narrower correction is possible.
- Provide a safe correction path: who should maintain the proposal, what should be transported, how to retest and when to remove any temporary test access.

WHAT PROVES THAT THE STEP IS COMPLETE

- Positive and negative SU24 samples.
- Object and field comparison test.
- Broad-access warning test.
- Recommendation reviewed by SAP Security and Basis or development owner.

Primary owner: SAP Security / GRC owner

STEP 9: IMPLEMENT THE ODATA AUTHORIZATION ANALYZER

In simple words: This component follows the service path and checks whether the exposed business operation is properly protected.

WHAT TO DO

- Capture service, version, entity set, operation, application and environment details.
- Inspect the supplied metadata and implementation evidence. Do not assume that service activation alone means authorization is correct.
- Check whether the operation has an authorization decision and whether it is applied for the relevant business fields or organizational values.
- Check whether the evidence identifies the implementation point, such as a method, handler or extension area, according to the target technology pattern.
- Separate technical reachability, authentication, authorization and business-data filtering. They are different questions.
- Return a clear correction and retest plan, including positive and negative user tests.

WHAT PROVES THAT THE STEP IS COMPLETE

- Read operation test.
- Change operation test.
- Unauthorized user test.
- Organizational-value filtering test.
- Unsupported or incomplete metadata test.

Primary owner: SAP Fiori / Gateway / SAP Security owner

STEP 10: BUILD EVIDENCE, FINDINGS AND REPORTING

In simple words: A report is trustworthy only when another person can understand how the conclusion was reached.

WHAT TO DO

- Create a finding ID and connect it to the request ID and analyzer version.
- Store a short evidence excerpt and a reference to the original source. Do not copy more data than necessary.
- Classify the root cause: missing authorization check, wrong object or field, misplaced check, missing SU24 proposal, weak OData protection, configuration gap, master-data issue, workflow issue, application defect, incomplete evidence or tool limitation.
- Calculate severity using business impact, exploitability, scope and evidence confidence. Keep severity separate from confidence.
- Show minimum correction first. Then show optional hardening or long-term improvement.
- Show retest steps and expected result in words a tester can follow.

- Generate an audit record containing requester, approver, timestamps, versions, decisions and links to the change record.

WHAT PROVES THAT THE STEP IS COMPLETE

- One complete report from each analyzer.
- Evidence-to-finding traceability test.
- Approval state test.
- Export or record-retention test.

Primary owner: Reporting and governance owner

STEP 11: CONNECT SAP EVIDENCE SOURCES SAFELY

In simple words: Connect only the evidence that is needed, and keep the first version read-only.

WHAT TO DO

- Identify the approved source for each evidence type: source repository or upload, SU24 extract, service metadata, trace or test result.
- Use a technical identity with read-only access and a clearly named purpose.
- Separate development, test and production connections. Never use a production credential in a test connector.
- Apply network, certificate, secret-storage and rotation standards defined by the enterprise platform team.
- Log the source system, client, user or service identity and retrieval time without exposing secrets.
- If a live connection is not approved, use a sanitized export and record that the result is based on supplied evidence rather than a live read.

WHAT PROVES THAT THE STEP IS COMPLETE

- Connection inventory.
- Read-only access proof.
- Secret rotation and expiry test.
- Environment separation test.
- Evidence retrieval audit record.

Primary owner: SAP Platform / Basis and AI Platform teams

STEP 12: APPLY SECURITY, PRIVACY AND OPERATIONAL GUARDRAILS

In simple words: Guardrails prevent a helpful assistant from becoming an unsafe access path.

WHAT TO DO

- Restrict who can submit requests, who can view reports and who can approve recommendations.
- Mask tokens, passwords, personal identifiers, customer records and unnecessary business data before analysis.
- Set maximum file size, request size, response size, processing time and retry limits.
- Block production write requests and any tool not present in the approved catalogue.
- Log every request and result, but protect the logs because they may contain sensitive technical evidence.
- Create a retention and deletion rule that matches the organization's information-security policy.
- Create a human escalation route for suspected false positives, data exposure or conflicting results.

WHAT PROVES THAT THE STEP IS COMPLETE

- Access-control matrix.
- Data-masking demonstration.
- Negative security tests.
- Retention and deletion approval.
- Incident escalation runbook.

Primary owner: Information Security, Privacy and AI Governance owners

STEP 13: PREPARE CHANGE MANAGEMENT AND HUMAN APPROVAL

In simple words: The assistant may identify a problem, but the organization's normal approval process remains the legal and operational control.

WHAT TO DO

- Define the approval states: Draft, Analyzed, Needs Evidence, Security Review, Development Review, Change Submitted, Retest Passed, Closed or Rejected.
- Assign the correct approver for each finding type. A code correction may need development ownership; a role or SU24 correction needs SAP Security ownership; a transport needs Change Management ownership.
- Ensure the proposed change includes minimum correction, impact, test plan, rollback or removal plan and evidence references.
- For temporary test access, record the reason, approver, start time, end time and removal confirmation.
- Do not allow the assistant to close a finding merely because it produced a recommendation. Closure requires human evidence of correction and retest.

WHAT PROVES THAT THE STEP IS COMPLETE

- Approval workflow diagram or configuration.
- Sample approved finding.
- Temporary-access expiry test.
- Change record linkage test.
- Closure evidence test.

Primary owner: SAP Security and Change Management

6. HOW ONE REQUEST MOVES THROUGH THE SOLUTION

Stage	What the user sees	What the system does	Control
1. Ask	User describes a security concern.	ICA identifies the likely checker.	No analysis before required details are present.
2. Confirm	User reviews the request summary.	ICA creates a structured input package.	User confirms scope and data classification.
3. Guard	Usually invisible to the user.	Gateway authenticates, validates and allow-lists the call.	Unauthorized tools are rejected.

4. Analyze	Progress and status message.	Bob invokes the selected analyzer or analyzers.	Read-only operation and timeout.
5. Explain	Finding with simple explanation.	System attaches evidence, root cause, severity and confidence.	No conclusion without evidence.
6. Decide	Reviewer accepts, rejects or asks for clarification.	Approval state and decision are recorded.	Human approval mandatory.
7. Remediate	Change reference and retest plan.	Normal SAP development and change process runs.	No direct production change by assistant.
8. Learn	Improved future answer.	Validated feedback updates rules and test cases.	Controlled versioning and review.

7. TESTING STRATEGY

7.1 TEST LEVELS

- Unit testing: each analyzer works correctly for small known examples.
- Contract testing: input and output fields match the agreed schema.
- Integration testing: ICA → Gateway → Bob → analyzer → report works end to end.
- Security testing: unauthorized users, tools, environments and write operations are blocked.
- Quality testing: findings point to the right evidence and do not overstate confidence.
- User acceptance testing: SAP Security, Development and business users understand and accept the result.
- Operational testing: timeout, retry, service outage, logging, alerting and recovery behave safely.

7.2 MINIMUM TEST PACK

Test ID	Scenario	Expected result
To1	Valid ABAP with correct authorization check	Pass or informational result with evidence.
To2	ABAP with missing check before sensitive operation	Finding points to exact statement or line and recommends correction.
To3	ABAP check exists only in unreachable branch	Finding explains reachability concern and confidence.
To4	SU24 proposal is missing	Finding identifies transaction/object/field and safe proposal correction.
To5	SU24 proposal is too broad	Warning separates proposal issue from role-design issue.
To6	OData read is protected; change is not	Finding is limited to the unprotected

		operation.
T07	Incomplete metadata	Needs More Evidence; no invented conclusion.
T08	Unauthorized tool requested	Gateway rejects request and logs reason.
T09	Production write requested	System blocks request and explains read-only boundary.
T10	Two analyzers disagree	Report shows both results and routes to human review.
T11	Sensitive value in input	Value is masked or request is rejected according to policy.
T12	Analyzer timeout	Safe error, no partial success presented as final answer.

8. PILOT APPROACH

Start with a small group and sanitized or non-production evidence. The pilot should prove usefulness, safety and repeatability—not simply produce impressive demonstrations.

- Select one SAP Security lead, one ABAP developer, one Fiori or Gateway specialist, one business representative and one AI Platform operator.
- Choose a small set of real historical issues whose outcomes are already known.
- Run the assistant in parallel with the existing manual review. Do not use it as the only control during the pilot.
- Compare accuracy, time saved, clarity, false positives, missing evidence and reviewer effort.
- Collect feedback on whether a non-specialist can understand the recommendation.
- Approve scale-up only when safety tests pass and the responsible owners agree that the findings are actionable.

PILOT SCORECARD

Measure	How to calculate it simply	Decision signal
Finding accuracy	Correct findings divided by reviewed findings	Must meet the agreed threshold.
Evidence precision	Findings with correct evidence reference divided by findings	Low score means the analyzer is not trustworthy.
False-positive rate	Incorrect findings divided by all findings	High rate increases reviewer burden.
Time saved	Manual review time minus assisted review time	Shows practical benefit.
Human override rate	Findings changed or rejected by reviewers	High rate requires rule or scope

		review.
Safety incidents	Any unauthorized access, exposure or write attempt	Target is zero.

9. PRODUCTION ROLLOUT IN CONTROLLED STAGES

Stage	Allowed capability	Required gate
Stage 0 — Build	Synthetic and sanitized samples only.	Schema, security and unit tests pass.
Stage 1 — Internal test	Read-only evidence from non-production.	Integration and UAT approval.
Stage 2 — Pilot	Small approved user group; known projects.	Pilot scorecard and risk review.
Stage 3 — Controlled adoption	Broader read-only analysis; human approval remains.	Operations, support and audit readiness.
Stage 4 — Scale	More projects and evidence types after separate approval.	Each new tool or write capability has its own design and approval.

10. DAY-TO-DAY OPERATING PROCEDURE

- Check the service health dashboard and confirm all three analyzers are available.
- Review rejected, timed-out and partially completed requests.
- Review high-severity findings and ensure they have a human owner.
- Check that temporary access and test permissions have not passed their expiry time.
- Review unusual request volumes or repeated failed authentication attempts.
- Confirm reports contain evidence and do not expose secrets.
- Record validated user feedback as a candidate rule or test-case improvement; do not silently change production behaviour.

11. OWNERSHIP MODEL

Role	Owns	Does not own
Business owner	Business meaning, priority and acceptance.	Technical authorization correction.
SAP Security	Rules, severity, authorization interpretation and security approval.	AI platform operations.
ABAP / SAP Development	Code correction, implementation evidence and developer retest.	Final security approval.
Fiori / Gateway	Service metadata and OData implementation	Business role approval.

specialist	evidence.	
AI Platform / MCP owner	Gateway, Bob/ICA integration, tool catalogue, reliability and logging.	SAP policy decisions.
Change Management	Change record, transport governance and closure evidence.	Analyzer logic.
Audit / Risk	Independent review of control effectiveness and evidence retention.	Daily technical support.

12. COMMON FAILURE SITUATIONS AND THE SAFE RESPONSE

Situation	Unsafe response	Safe response
Missing source include	Guess that the called routine is safe.	Say that evidence is incomplete and request the missing include or trace.
Only technical service metadata available	Claim that business authorization is correct.	Separate reachability from authorization and mark the finding as needing evidence.
User asks for direct role assignment	Grant access from the assistant.	Explain that the assistant can recommend minimum access and route it through approval.
High severity but low confidence	Present it as a confirmed defect.	Show both values and require expert review.
Temporary UAT access needed	Leave broad access permanently.	Record minimum access, expiry and removal confirmation.
Analyzer outage	Return a cached result as current.	Show service error and identify the timestamp and version of any prior result.

13. DEFINITION OF DONE

The implementation is ready for controlled adoption only when all of these are true

The scope is approved; inputs are classified and masked; schemas are versioned; tools are allow-listed; Bob and ICA stop safely; all three analyzers provide evidence-backed results; production write operations are blocked; human approval and change records are connected; pilot results are accepted; monitoring, support and audit procedures are documented.

- A new user can complete a request without needing to know the internal architecture.
- A security reviewer can identify the exact statement, object, service or evidence that caused a finding.

- A developer can understand the recommended correction and how to retest it.
- An auditor can reconstruct who submitted, analyzed, approved, changed and closed the item.
- The system refuses unsafe, unsupported or incomplete requests instead of inventing an answer.

APPENDIX A — STANDARD FINDING RECORD

Field	What to write in plain language
Finding ID	A unique number for this issue.
Checker	ABAP, SU24 or OData.
Status	Pass, Finding, Needs More Evidence, Not Applicable or Tool Error.
Severity	How serious the business or security impact could be.
Confidence	How certain the system is based on the evidence received.
Business action	What the user or system is trying to do.
Technical location	Program and line, transaction/object/field, or service/entity/operation.
Evidence	The small source excerpt, trace or configuration proof.
Root cause	Why the gap exists.
Minimum correction	The smallest safe change that addresses the finding.
Corrected example	Illustrative code or configuration pattern for expert review.
Retest	The positive and negative tests to perform.
Limitation	What was not available or could not be verified.
Approval	Who accepted, rejected or requested more evidence.
Change reference	The approved ticket, transport or implementation record.

APPENDIX B — EXAMPLE RESULT IN VERY SIMPLE LANGUAGE

Example finding: Missing ABAP authorization check

The program performs a sensitive change for a sales document, but the supplied code does not show an authorization check immediately before the change. The analyzer points to the exact statement. The likely risk is that a user who can reach the program may perform the action outside the intended business-role boundary. Confidence is High for the supplied code, but the result must be rechecked if the authorization decision happens in a called routine that was not included. Recommended action: developer adds the

approved authorization-check pattern, SAP Security confirms the object and field values, the change is transported through the normal process, and a positive/negative test is completed.

APPENDIX C — GO-LIVE CHECKLIST

- Scope and out-of-scope list approved.
- Tool catalogue and versions approved.
- All connections are read-only for the first release.
- Production write operations are disabled and tested as blocked.
- Input masking and retention rules approved.
- Access matrix and approvers defined.
- All minimum test cases passed.
- Pilot scorecard reviewed.
- Support and incident contacts published.
- Monitoring and alerting enabled.
- Human approval and Change Management linkage tested.
- Rollback or disablement procedure tested.
- User communication and training completed.

APPENDIX D — ONE-PAGE EXPLANATION FOR A NON-TECHNICAL STAKEHOLDER

This solution is a controlled assistant for SAP authorization reviews. A person provides code or service evidence and explains the business action. ICA asks for missing information. MCP Gateway checks that only approved analysis tools are used. IBM Bob coordinates three checks: ABAP authorization statements, SU24 proposals and OData service protection. The assistant then produces a report showing what it found, why it matters, what evidence supports the finding, what correction is suggested and how to test the correction. It does not automatically grant access or change production. A qualified human reviews and approves every meaningful action. Access Link: <https://lighter-phpbb-roommate-reserved.trycloudflare.com/>

